

Mobile Asset Theft: CherryBlos Malware Campaign

1. Introduction

The rapid growth of Decentralized Finance has massively changed the power of financial structure, with the key responsibility for asset protection being handed to the end users. The main entry point for this new and recent system is using the mobile cryptocurrency wallet, which allows users to access their digital assets. However, this has also led to the development of many structural weaknesses that most banking systems are protected against. These weaknesses include things such as institutional safety nets and transaction reversal, which Decentralized Finance lacks (MITRE ATT&CK, n.d.).

The malware CherryBlos first showed up in 2023 and was a complex malware attack that specifically targeted Android devices. It was designed to exploit the structural weaknesses discussed earlier. By combining social engineering, service abuse, and data-extraction methodologies, CherryBlos was able to successfully target the fundamental private seed phrase which is critical for users to keep their accounts secure.

This malware attack revealed critical weaknesses in the trust-based models of mobile application ecosystems and decentralized security (28 et al., 2023), which then eventually prompted an evolution towards hardware-based security measures and more rigorous automated screening processes on Android.

2. Mobile DeFi

The technology which was involved in this attack is related to the Non-Custodial Mobile Cryptocurrency Wallet. Basically non-custodial wallets are different from custodial wallets because they use a traditional bank or a centralized exchange on the Play Store like Coinbase and give users sole control over their private keys.

Three key elements need to be addressed to dive into this problem deeper:

1. **Seed Phrases:** Most wallets use a “mnemonic seed phrase,” which is basically a combination of 12 to 24 random words. This phrase is the master key to their wallet, and anyone who has the phrase has complete control over the assets.
2. **Android App Distribution:** Even though the Google Play Store is the primary source of app downloads, the Android operating system allows for “sideloading” (basically a way to install apps from third-party websites or Telegram channels), which then creates this loophole that is able to evade official security scans and allows users to download “pirated” versions of apps from third-party sources (Google. (n.d.).).
3. **The Structural Weakness:** In the DeFi system, there is no way for you to simply “Forget Password” or go to some form of fraud department to go back on your account or assist (especially if the downloaded version is “Pirated”). Once your seed phrase is lost and the transaction is confirmed on the blockchain, it is irreversible. CherryBlos exploited this exact weakness to ensure that this was a high-impact financial theft.

3. CherryBlos Attack Analysis

CherryBlos was first discovered by the Trend Micro team in mid-2023. The complexity of CherryBlos is in its multi-stage execution and Optical Character Recognition (OCR) which searches for embedded seed phrases in images (The Hacker News).

MITRE ATT&CK® Navigator Layers

The following table shows the specific adversarial tactics and techniques used by CherryBlos (Software ID: S1225):

about			domain			platforms			legend		
CherryBlos (S1225)			Mobile ATT&CK v18			Android, iOS			0.00.330.671.0 used by CherryBlos		
Application Varianting	Command and Scripting Interpreter	Boot or Login Initialization Scripts	Abuse Elevation Control Mechanism	Application Varianting	Abuse Accessibility Features	File and Directory Discovery	Exploitation of Remote Services	Abuse Accessibility Features	Application Layer Protocol	Exfiltration Over Alternative Protocol	Account Access Removal
Drive-by Compromise	Unix Shell	Compromise Application Executable	Device Administrator Permissions	Download New Code at Runtime	Access Notifications	Location Tracking	Replication Through Removable Media	Access Notifications	Web Protocols	Exfiltration Over Unencrypted Non-C2 Protocol	Call Control
Exploitation for Initial Access	Exploitation for Client Execution	Compromise Client Software Binary	Exploitation for Privilege Escalation	Execution Guardrails	Clipboard Data	Impermeable SST Nodes		Adversary-in-the-Middle	Call Control	Exfiltration Over C2 Channel	Data Destruction
Lockscreen Bypass	Native API	Event Triggered Execution	Process Injection	Defencing	Credentials from Password Store	Remote Device Management Services		Archive Collected Data	Dynamic Resolution		Data Encrypted for Impact
Phishing	Scheduled Task/Job	Broadcast Receivers	Ptrace System Calls	Foreground Persistence	Keychain	Network Service Scanning		Audio Capture	Domain Generation Algorithms		Data Manipulation
Replication Through Removable Media		Foreground Persistence		Side Artifacts	Input Capture	Process Discovery		Call Control	Encrypted Channel		Transmitted Data Manipulation
SIM Card Swap		Hijack Execution Flow		Conceal Multimedia File	OSI Input Capture	Software Discovery		Clipboard Data	Asymmetric Cryptography		Endpoint Denial of Service
Supply Chain Compromise		System Runtime API Hijacking		Suppress Application Icon	Keylogging	Security Software Discovery		Data from Local System	SSL Pinning		Generate Traffic from Victim
Compromise Hardware Supply Chain		Linked Devices		User Evasion	Steal Application Access Token	System Information Discovery		Input Capture	Symmetric Cryptography		Input Injection
Compromise Software Dependencies and Development Tools		Scheduled Task/Job		Hooking	OSI Hijacking	System Network Configuration Discovery		OSI Input Capture	Ingress Tool Transfer		Network Denial of Service
Compromise Software Supply Chain				Inputs		Internet Connection Discovery		Keylogging	Non-Standard Port		OSI Control
				Device Lockout		Wi-Fi Discovery		Linked Devices	Out of Band Data		
				Disable or Modify Tools		System Network Connections Discovery		Location Tracking	Remote Access Software		
				Prevent Application Removal				Impermeable OSI Nodes	Web Service		
				Indicators				Remote Device Management Services	Bi-directional Communication		
				Removal or Root Disguise				Protected User Data	Dead Drop Resolver		
				Root/Jailbreak Indicators				Accounts	One-Way Communication		
				File Deletion				Calendar Entries			
				Uninstall Malicious Application				Call Log			
				Input Injection				Contact List			
				Manpowering				Screen Capture			
				Match Legitimate Name or Location				Stored Application Data			
				Native API Obfuscated Files or Information				Video Capture			
				Software Packing							
				Steganography							
				Process Injection							
				Ptrace System Calls							
				Proxy Through Victim							
				Subvert Trust Controls							
				Code Signing Policy Modification							
				Virtualization Solution							
				Virtualization/Sandbox Emulation							
				System Checks							

Adversary Goal and Weakness Exploited

The primary objective of this malware was direct financial theft. CherryBlos was not interested in typical data like emails, but rather in the “key” to the cryptocurrency market (which was the seed phrases).

- **OCR Innovation:** The most malicious aspect of this malware was its ability to scan a user’s photo gallery for screenshots of seed phrases. Users tend to take screenshots of their recovery phrases during the setup process despite warnings, and CherryBlos automated the search for these “digital master keys.”
- **Accessibility Abuse:** The malware also used a form of social engineering where it tricked users into turning on “Accessibility Services” (which was meant for disabled users) so that it could automatically approve more permissions, and then it went ahead and projected fake screens over real banking apps to steal passwords.

4. Evolution of Technology and Defenses

The effects of CherryBlos and other forms of malware have hardened the mobile security landscape. In essence, the state of mobile security before the 2023 wave was that it was entirely dependent on Google Play Protect and signature-based detections. However, CherryBlos used commercial software packers (such as Jiagubao) to conceal its code from static analysis.

The Evolution of Mobile Application Security:

The main evolution began with the implementation and adoption of Hardware-Backed Keystores, in which the latest Android wallets started using the Hardware Security Modules (HSM) to ensure that the user’s private keys never stayed in the main OS memory, where the malware could access them.

This was also followed by the implementation of Screenshot Blocking, where new finance apps began to leverage the FLAG_SECURE window attribute to prevent the OS (and malware such as CherryBlos) from taking screenshots or recording the screen.

Furthermore, there was also a change in the policies during 2025. This is where Google introduced a more rigid Cryptocurrency Exchanges and Software Wallets Policy. This change in policy made it compulsory for developers in certain regions to submit proof of government licensing which made it difficult for “scam” apps to remain in the store.

5. Future Issues

Of course, as the tactics of adversaries evolve from simple code to social engineering using AI in today's day and age, I think that the "Worst-Case Scenario" for information warfare is the erosion of digital trust. Some future threats that are devastating could include things such as:

- **Deepfake Support Scams:** The use of AI voices to trick users into "verifying" their wallets over the phone is a threat that is becoming more and more inevitable.
- **Supply Chain Injection:** Open-source libraries (such as SDKs on mobile devices) that the wallet's software uses could potentially infect millions of users at the source if not handled with care and precaution.

All in all, CherryBlos was quite the turning point at least in terms of mobile security. It showed the world that in the realm of DeFi, an attacker no longer needs to crack the blockchain's encryption or even try to, instead, they only need to compromise user behavior and device visibility.

References

Cherryblos. CherryBlos, Software S1225 | MITRE ATT&CK®. (n.d.).

<https://attack.mitre.org/software/S1225/>

28, B. T. M. Research Jul, Authors, Micro, T. M. Research Trend, Research, T. M., Trend Micro, & Us, C. (2023, July 28). *Related cherryblos and Faketrade Android malware involved in scam campaigns*. Trend Micro.

https://www.trendmicro.com/en_us/research/23/g/cherryblos-and-faketrade-android-malware-involved-in-scam-campai.html

The Hacker News. (2023, July 31). *New android malware cherryblos utilizing OCR to steal sensitive data*. <https://thehackernews.com/2023/07/new-android-malware-cherryblos.html>

Google. (n.d.). *Understanding google play's cryptocurrency exchanges and software wallets policy - play console help*. Google.

<https://support.google.com/googleplay/android-developer/answer/16329703?hl=en>